

Seguridad de red

Una subred pública sin filtro es una puerta abierta de par en par

Cualquier instancia que lances ahí queda expuesta a todo internet, en todos sus puertos —el número que identifica a qué servicio va dirigida una conexión, como el 80 de un servidor web—, salvo que añadas algo que decida quién entra.

Hoy añades tres piezas

Dos capas de filtrado

Que se confunden constantemente entre sí.

SSH sin exponer

El hábito de administrar sin dejar el puerto abierto al mundo.

Salida sin entrada

Cómo una subred privada sale a internet sin dejar de ser inalcanzable.

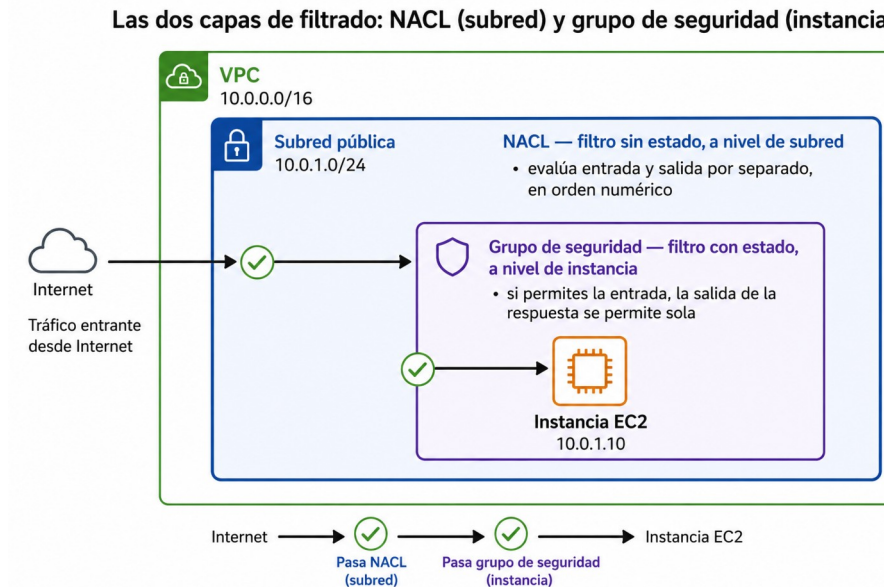
Grupos de seguridad frente a NACL

Dos herramientas de filtrado, y confundirlas es de los errores más repetidos del curso. Deciden qué tráfico entra y sale, pero a nivel distinto y de forma distinta.

	Grupo de seguridad	NACL
Se aplica a	La instancia (el recurso concreto)	La subred entera
¿Tiene estado?	Con estado: la respuesta se permite sola	Sin estado: entrada y salida por separado
Reglas	Solo de «permitir»	De «permitir» y de «denegar» explícito
Orden de evaluación	Se evalúan todas las que apliquen	Orden numérico: la primera que coincide gana

Por qué se confunden tanto

Un portero de discoteca (grupo de seguridad) recuerda a quién dejó entrar: al salir, no vuelve a pedir el carné —«con estado»—. La verja del recinto (NACL) no recuerda nada: cada cruce, en cualquier sentido, se comprueba de nuevo —«sin estado»—.

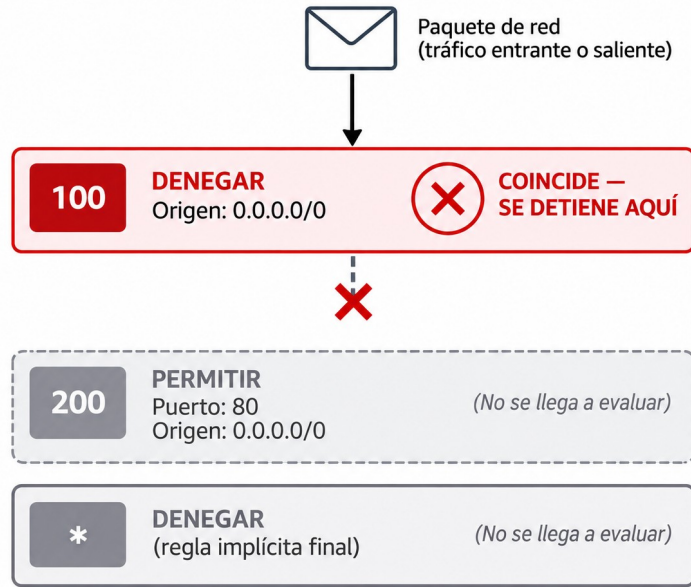


Si olvidas una regla de salida en un SG, no pasa nada

Si la olvidas en una NACL, el tráfico se corta aunque la entrada estuviera permitida.

El orden importa: una NACL mal ordenada bloquea

Cómo evalúa AWS las reglas de una NACL, en orden



i Se evalúa en orden numérico. La primera regla que coincide gana — no importa si una regla posterior sería más permisiva.

Regla 100: deniega todo desde 0.0.0.0/0

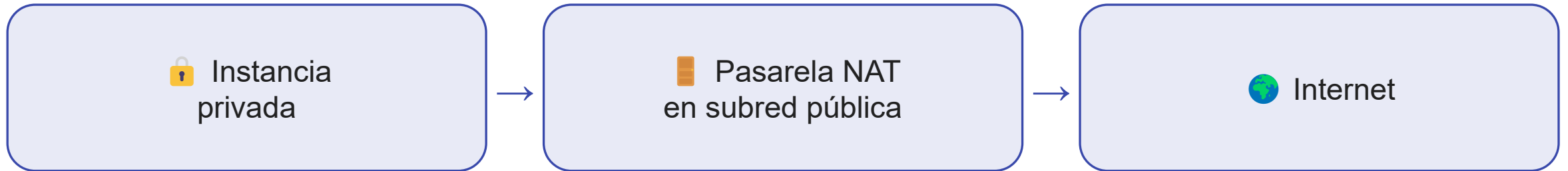
Regla 200 (añadida después): permite el puerto 80 desde ese mismo origen. AWS evalúa en orden numérico y se queda con la primera que coincide.

La 100 gana, aunque la 200 «diga que sí»

El tráfico se bloquea igual. La solución no es borrar la 100 — es darle a la regla de permitir un número más bajo que el de la que deniega.

NAT y su coste

Una subred privada no tiene ruta a la pasarela de internet, así que tampoco puede salir. Pero a veces necesita salir —actualizar paquetes, llamar a un servicio externo— sin dejar de ser inalcanzable desde fuera.



El tráfico sale con la IP de la pasarela

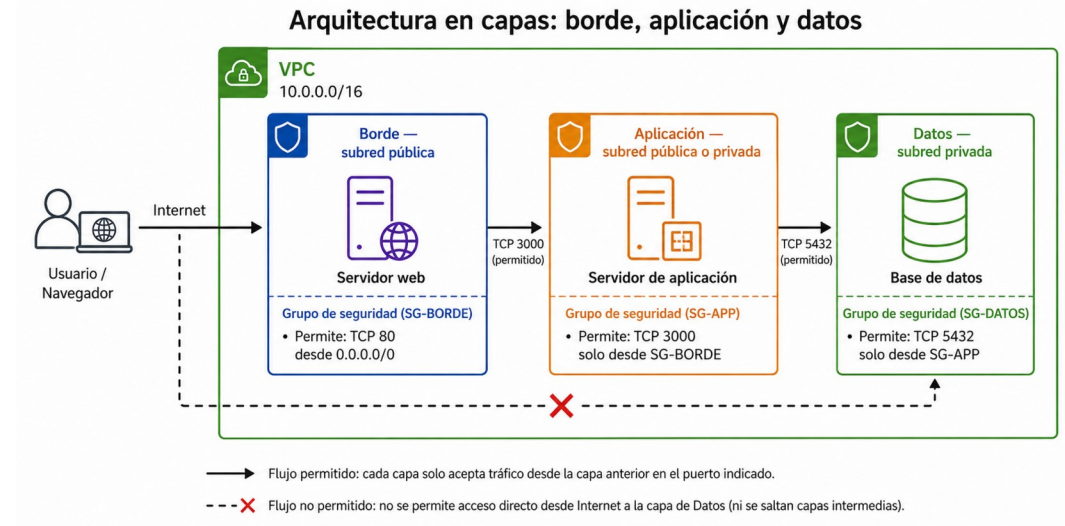
Nunca con la de la instancia privada, así que nadie de fuera puede iniciar una conexión de vuelta hacia ella.

La pasarela NAT no es gratis

A diferencia de la de internet, cobra por hora encendida y por GB. Suele ser una de las líneas más caras de una arquitectura pequeña — lo calcularás en la Actividad 2.2.

Arquitectura en capas: borde, aplicación y datos

Con SG, NACL y NAT ya puedes construir el patrón que repetirás en cada arquitectura: capas concéntricas donde cada una solo habla con la de al lado, nunca se salta ninguna.



Puerto	Qué es
80	El puerto estándar de un servidor web
3000	No es «oficial»: lo elige el desarrollador del servidor de aplicación
5432	El puerto por defecto de PostgreSQL — este sí es fijo

La regla de la capa de datos, en concreto

Cada flecha del diagrama es una regla de grupo de seguridad

La capa de datos solo acepta tráfico que venga de la capa de aplicación, nunca directamente de internet ni desde el borde.

Una única regla de entrada

Puerto 5432, origen el grupo de seguridad de la capa de aplicación — nunca 0.0.0.0/0, ni siquiera el puerto 80 del borde. La construirás al conectar una base de datos gestionada en el Tema 3.

Acceso administrativo sin exponer SSH

Abrir el puerto 22 a 0.0.0.0/0 es de los errores más buscados por atacantes automatizados, que escanean internet constantemente. Tres formas de organizarlo, de más expuesta a más segura:

Práctica	Qué hace	Nivel de exposición
SSH abierto a 0.0.0.0/0	Cualquier IP del planeta puede intentarlo	Máximo — evítalo siempre
SSH restringido a tu IP	Solo tu dirección actual puede conectarse	Bajo, pero cambia si te mueves de red
Sin IP pública, acceso vía instancia intermedia	La instancia administrada nunca es alcanzable directamente	Mínimo

El patrón bastión, ya lo has usado

Restringir el SG de SSH a tu IP es una línea, y la aplicarás en la 2.2. Pero en la 2.1 ya saltaste por SSH desde tu instancia pública hasta la privada, sin que esta tuviera nunca IP pública ni una regla abierta a internet.



Esa instancia de salto se llama bastión (bastion host)

Es exactamente el patrón que acabas de usar, y lo formalizarás y reutilizarás en arquitecturas completas más adelante en el módulo.

Ideas clave

1

Grupo de seguridad = filtro con estado a nivel de instancia; NACL = filtro sin estado a nivel de subred. Las dos se evalúan siempre.

2

Con estado: el SG recuerda la conexión y permite la respuesta sola. Sin estado: la NACL exige entrada y salida por separado.

3

La pasarela NAT da salida a internet a las subredes privadas sin permitir entrada — y tiene coste por hora y por GB.

4

Arquitectura en capas (borde → aplicación → datos): cada capa solo habla con la de al lado, nunca se salta ninguna.

5

SSH nunca debe quedar abierto a 0.0.0.0/0 — restringir el origen a tu propia IP es la primera línea de defensa.